

PENETRATION TESTING REPORT

MEDIROZA GENERAL HOSPITAL

Web Application Security Assessment

Target

<https://medirozahospital.com>

Assessment Type

Authorized Black-Box Penetration Test

Prepared For

Mediroza General Hospital

Prepared By

Albina Shakil

Report Date

1st October, 2026

CONFIDENTIAL

This document contains confidential security assessment information and is intended solely for authorized recipients.

1. EXECUTIVE SUMMARY

An authorized black-box penetration test was conducted against the Mediroza General Hospital web application at <https://medirozahospital.com> to identify security weaknesses that could expose sensitive patient, employee, and business information.

During the assessment, a SQL injection vulnerability was identified in the patient login functionality, which allowed authentication to be bypassed and provided access to three confidential patient laboratory reports. The reports were password protected and were subjected to dictionary-based password testing.

The assessment also identified a publicly accessible directory containing an exposed database backup. The backup contained staff information, including salary-related data, as well as shareholder information.

The findings demonstrate weaknesses in input validation, authentication, access control, and protection of sensitive backup data. Appropriate remediation is recommended to prevent unauthorized access and reduce the risk of sensitive information exposure.

2. SCOPE AND METHODOLOGY

Scope

The assessment was limited to the web application hosted at:

<https://medirozahospital.com>

Testing was conducted as an authorized black-box security assessment. Testing focused on identifying vulnerabilities that could allow unauthorized access to patient records, sensitive employee information, and business information.

Out-of-scope activities included denial-of-service testing, social engineering, destructive actions, and testing systems outside the authorized target.

Methodology

The assessment followed a practical penetration testing process:

- Reconnaissance and information gathering
- Directory and file enumeration
- Authentication and input validation testing
- Vulnerability identification and exploitation
- Validation of unauthorized access
- Sensitive data exposure assessment
- Password recovery testing of retrieved PDF reports
- Evidence collection and documentation

3. FINDINGS AND PROOF OF EXPLOITATION

3.1 SQL Injection and Authentication Bypass

Risk Rating: CRITICAL

The patient login functionality was vulnerable to SQL injection. A single quotation mark generated a MySQL syntax error, indicating insufficient input handling. Further testing confirmed the existence of the admin username, and a controlled SQL injection payload successfully bypassed authentication and provided access to the patient portal.

Impact: An attacker could bypass authentication without the legitimate password and gain unauthorized access to protected information.

3.2 Unauthorized Access to Patient Reports

Risk Rating: CRITICAL

Following the authentication bypass, the patient portal provided access to three confidential laboratory reports. All three reports were successfully retrieved during the authorized assessment.

The reports were password protected. Dictionary-based password testing was performed, and after the initial wordlist failed, the larger **JTR_default_password.txt** wordlist successfully recovered the passwords for all three reports.

Impact: An attacker could gain access to confidential patient medical information and potentially recover the contents of protected reports.

3.3 Publicly Accessible Database Backup

Risk Rating: CRITICAL

The website's robots.txt file revealed an **/old/** directory. Direct access to this directory displayed a directory listing containing **mediroza_db_backup_2019.sql**.

The backup was accessible without authentication and contained sensitive staff and shareholder information.

Impact: Public exposure of the database backup allows unauthorized users to obtain sensitive personal and organizational information.

3.4 Sensitive Staff and Shareholder Information Exposure

Risk Rating: HIGH

The exposed database backup contained staff records including names, job titles, departments, contact information, national identification information, monthly salaries, and joining dates. It also contained shareholder information including names, ownership percentages, shares held, and share classes.

Impact: Exposure of employee, salary, and corporate ownership information creates significant privacy and confidentiality risks.

4. RISK RATING

The following table summarizes the severity of the vulnerabilities identified during the assessment.

Finding	Risk Rating
SQL Injection and Authentication Bypass	CRITICAL
Unauthorized Access to Patient Reports	CRITICAL
Publicly Accessible Database Backup	CRITICAL
Sensitive Staff and Shareholder Information Exposure	HIGH

5. RECOMMENDATIONS AND REMEDIATION

- Use prepared statements and server-side input validation to prevent SQL injection.
- Strengthen authentication and enforce server-side authorization for patient records.
- Remove database backups from public directories and disable unnecessary directory listing.
- Store backups securely with appropriate access controls and encryption.
- Restrict access to employee, salary, patient, and shareholder information.
- Review the application and server configuration for similar exposures.

6. CONCLUSION

The assessment identified critical weaknesses in authentication, access control, and protection of sensitive data. The demonstrated SQL injection allowed unauthorized access to patient reports, while the publicly accessible database backup exposed employee and shareholder information. Addressing the identified vulnerabilities and implementing stronger access controls will significantly improve the security of the application and its sensitive data.